

From: Patrick T. Stingley

To: [REDACTED]

Subject: "Input [to] the Development of an Artificial Intelligence (AI) Action Plan..."

"This document is approved for public dissemination. The document contains no business-proprietary or confidential information. Document contents may be reused by the government in developing the AI Action Plan and associated documents without attribution."

Responses can address any relevant AI policy topic, including but not limited to: hardware and chips, data centers, energy consumption and efficiency, model development, open source development, application and use (either in the private sector or by government), explainability and assurance of AI model outputs, cybersecurity, data privacy and security throughout the lifecycle of AI system development and deployment (to include security against AI model attacks), risks, regulation and governance, technical and safety standards, national security and defense, research and development, education and workforce, innovation and competition, intellectual property, procurement, international collaboration, and export controls.

Apply Business Process Re-Engineering to the Federal Government

We currently have a Department of Education that educates no-one, yet the Department of Agriculture operates a graduate school. We have an Office of Personnel Management that doesn't hire for anybody but their own staff. The Department of the Interior's IBC provides general IT services instead of the General Services Agency (GSA). Why don't we normalize these functions?

One of the reasons the Federal Government has such large staffs is because each Agency has had to establish their own set of hidden factories to perform these functions. Artificial Intelligence, Agentic AI, and Robotic Process Automation can allow Agencies in the Federal Government to provide government wide services that they previously were unable to deliver.

To begin this process, the Federal Government needs to re-establish the office of the Chief Architect in the Office of Management and Budget (OMB). The Clinger-Cohen Act requires the Government to take an "architectural approach to IT investment". However, OMB has not collected enterprise architectures since the Obama administration. As the Government goes through this re-work process, having Enterprise Architectures of the systems involved would be advantageous. With the Agencies' Enterprise Architectures in hand, it would be possible to identify redundant systems and consolidate them. Without

these Enterprise Architectures, it will be impossible to see the redundancies and consolidation is likely to cause many unintended and undesirable side effects.

The office of the Chief Architect has been vacant for many years and the Federal Enterprise Architecture Framework (FEAF) has not been updated in more than a dozen years. Many new technologies have been invented since that time. As a result of this, those agencies that are still complying with Clinger-Cohn have been extending their own versions of the FEAF in their own unique ways. This means that when OMB collects information about how IT dollars are being spent, the feedback they get is inconsistent across the Agencies (i.e., garbage). Converting to the Technology Business Model (TBM) a couple of years ago did not remedy this situation because there is no consensus across investment categories. It is recommended that whoever is reading this, please consult with the Federal IT Investment Management Community of Practice to verify these assertions.

The General Services Agency (GSA) - Why can't all of the government buy the things they need from GSA? Procurement amounts to a pervasive collection of hidden factories (in the ITIL sense of the term) across all of the Agencies in the Government. With today's automated tools, why can't a Geologist in Ely Nevada buy software he needs or a GPS device from a website from GSA and have, have it approved by his supervisor, have the funding code for his organization pay for it, have it be part of a bulk contract at GSA and have it shipped to her in Ely Nevada?

Further, if it is software, there is no reason that it can't be installed remotely. Currently, most Agencies use a system called BigFix as both an inventory collection system as well as a means of installing software. It would be possible for a system at GSA to send a fixlet to the BigFix instance at any of these agencies to have software installed.

From this author's experience in the Government over many years, the software inventory is out of control. This leads to additional costs due to data inconsistencies, inconsistent tools, training etc. In addition to this, every unique piece of software represents its own threat vectors from an IT Security point of view. Having software installed by automated means would be a good way of addressing these problems.

Many Bureaus, perhaps Agencies, should not have their own IT. One organization this author is familiar with has spent the last 30 years essentially writing and rewriting their own version of a document management system, while at the same time, wasting a half a billion dollars on another failed system they eventually abandoned. Services is the central word in the General Services Agency. Thus, it is within their purview to provide information services across the Government. Is a document management system for one agency really

different from a document management system for another? Currently, the Department of the Interior is providing IT services across the Government. That makes no sense at all.

The Computer Information Security Agency (CISA) – Part of the ordering process from GSA would be to go a whitelist maintained by either CISA or the National Institutes of Standards and Technology (NIST). When a Commercial Off The Shelf (COTS) product is ordered, it should be compared to a whitelist of approved hardware / software maintained by one of these Agencies.

Establish automated security testing at CISA. Software testing to comply with FISMA testing requirements is another source of hidden factories across the Government. Each bureau within each Agency is responsible for testing their own software. This results in uneven levels of testing, if it is done at all. This author has personally seen some Bureaus simply grandfather in software because the amount of software exceeded their ability to test it.

After the end of COVID, one organization I am familiar with received 3,000 new versions of software in one month. No Agency in the Government is able to test 3,000 things in a single month, maybe not even in a single year. So, it is doubtful that any agency in the Federal Government is currently compliant with existing FISMA testing requirements.

A centralized testing capability would provide consistent testing and would be more efficient than having every corner of the Government test and re-test the same software, while not having the resources to test the rest of it.

One of these two agencies should test all new versions of software detected by BigFix, they should be able to collect a copy of it and run it through an automated test to determine if it poses a risk. By doing this, CISA / NIST would be establishing a whitelist of software that was known to be good. This would include the hash values identifying the exact binary configuration of the software that is allowable on Government computers.

In the use-case given above wherein a customer was trying to purchase something, their request would be compared against the whitelist to determine if it is approved or not. If so, then a message goes back to GSA saying that it's OK to purchase it. If the product has not been tested, then that would kick off an automated testing process at CISA.

There are Artificial Intelligence tools that can un-compile compiled software. Artificial Intelligence tools are also able to document code, so it is possible to identify malware as well as to spot COTS software with problems such as buffer overflows using these tools.

If the product is something that the Government doesn't want on its network, then a refusal message would be sent back to GSA to be conveyed back to the customer. Much of this can be done in minutes, resulting in better service for the customer.

There are going to be cases where existing products need to be removed from the government inventory. In the case of software, if the organization uses BigFix, this can be done automatically. In these cases, CISA can send a message to the BigFix servers to delete the software immediately. I call this the "Silver Bullet". Once a virus attacks a system, it takes on average 9 minutes for that malware to identify and attack another system. CISA needs a "Silver Bullet" capability to respond in a timely manner. The current CVE process is slow, antiquated and relies on the voluntary actions of a collection of hidden factories of systems administrators across the Government to take action. Viruses work autonomously; the response system needs to be autonomous too.

Testing needs to address scripts - Establish an automatic source code and script harvester in each agency. With tools like ChatGPT, it is possible for employees who can't even program to have programs written for them that do dangerous things. A couple of examples that come to mind were recently when an employee used ChatGPT to write a Telnet client and a Finger client completely undetectable to the security systems in place. Current IT security measures don't consider scripts. Thus, it is recommended that every organization in the Government have a program that looks for scripts (.py, .js, .bat etc.) on user computers, documents them and what they do, pushes them to a GIT repository where they can be indexed, searched and found. ChatGPT does an excellent job of reading code, documenting it and describing what it does, so this could be done in an automated fashion.

CISA's CDM program needs to collect the hash values of all compiled software and comparing those values against known good hash values to determine when an application has been corrupted by a virus, malware or other activity. Second, CISA needs to collect these hash values in order to determine if the software has been patched. These requirements originally part of the CDM project have not been met.

OPM (Office of Personnel Management) – The United States Government may be the only organization in the world that has a human resources branch (the Office of Personnel Management) that does not actually hire people. The only people OPM hires is for OPM.

As a result of this, there are hundreds if not thousands of hidden factories across the government within which the hiring, firing, on-boarding and off-boarding of government employees is done – with varying degrees of success.

When an organization, wants to hire employees, they are supplied standardized words for the position, standardized scripts to ask prospective employees to respond to. The

resumes are processed by a computer system and forwarded on to the hiring manager for selection. Then, when the employee is offered the job, they have to fill in the same information again. This information is then entered again into a system that sends it to OPM. SF-50s are generated, again with varying levels of success. Then the employee is on-boarded over the course of 90 days.

This entire process could be done by OPM using Robotic Process Automation (RPA) augmented with Artificial Intelligence. By using RPA, the strict rules of Privacy and data protection could be maintained and the process could be managed in a consistent manner. By augmenting it with AI, it would be possible to handle the unique situations that will crop up. An AI tool would also be extremely helpful in answering questions from employees.

It is believed that the center of OPM's technology is an IBM mainframe. There is no problem with that. To the best of my knowledge nobody has ever broken the security of RAC-F. It is the best security known. But having a mainframe also means that updates are typically done nightly. There is no reason that the on-boarding process couldn't be achieved the day after the employee starts by taking the data from the hiring process and providing a form to the employee before their actual start date. There is no excuse for on-boarding to take 90 days.

On the first day of work, a new employee can log on to the network, so clearly their identity is known in Active Directory. Their supervisor is known, their phone number, office number and e-mail address are all known. There is no excuse that the on-boarding process takes three months.

It is recommended that on-boarding and off-boarding be a standardized process run by OPM, rather than farmed out to hidden factories across the Government. The current hiring process, as well as the off-boarding processes are really the same paper-based processes that existed from before the Internet existed, just with a veneer of automation applied. There has been no attempt to revisit the HR processes across the U.S. Government as a whole.

The results of this *modus operandi* are appalling. In the case of this author, the person who did the on-boarding failed to set up automatic deduction for health insurance. Five years later, when a change was needed, this error was detected and \$10,000 in back fees had to be paid to the insurance company, which meant no paycheck for a couple of months.

This same author's SF-50 did not have the duty station on it for the last 12 years. The closest duty station is Washington DC, but the work is actually a remote position working for people located in Denver, as has been the situation for the last 9 years, yet it was not

recorded. As one can imagine, this has posed significant problems recently, due to the return to office mandate.

This week the entire Bureau where this author works was given a set of specifications about SF-50s and told to review and repair issues with their own SF-50s. I doubt this will make the situation better because few of us are trained in what an SF-50 should look like. This author has never had such a class. It is likely that every Agency has problems with quality control when it comes to the SF-50. The quality of all of the Human Resource functions would be improved and certainly more consistent if they were standardized, centralized and fully automated. In the case of Human Resources, the human in the loop has been the source of the problems, not the remedy. If these functions were provided by OPM, then processes could be adjusted all at once as laws and regulations changed. Rather than thousands of staff personnel in each corner of each organization, a central system with a highly trained helpdesk would serve the Government better.

Consider the Thrift Savings Plan as a good model. It is handled centrally and a phone call to their helpdesk works well.

Beneficial Suggestion Program – The laws exist to encourage employees to be innovative, but this has been largely forgotten. In the Government's millions of employees, it is mathematically impossible that none of them are intelligent and that none of them have good ideas. There is no effort to leverage these talents or ideas.

Educate the workforce. Education should be a requirement in IT. This author does Artificial Intelligence Research and Data Science. When I went to my Branch Director to pay for courses that were directly related to the accomplishment of the job, he didn't even know how to accomplish that because nobody else in the entire IT shop working for him had ever taken a course!

How can the government keep up with advancements in IT when the employees are not continuously learning? Since then, my supervisor has reneged on reimbursing me for classes. Classes that were directly in keeping with my job have been denied. How can the Federal Government keep up with advances in technology like Artificial Intelligence when the employees are not being continuously educated?

The government may be having difficulty hiring technical talent, but this need not be the case if access to education was part of the position. The Government needs to establish a culture of education and continual improvement.

U.S. Department of Agriculture – Why is the USDA operating a graduate school and the Department of Education provides no education to anybody? This makes no sense. It is recommended that the Department of Education run the government's civilian schools.

This concludes the discussion of using Business Process Management to help the Government effectively use Artificial Intelligence to streamline its operations. The following are some additional measures that are recommended in response to the Request for Information:

1. With respect to data centers, energy consumption and efficiency: The Bureau of Land Management leases public land for solar farms and wind arrays. The electricity produced by these renewable energy systems is then sent over long distances, losing some of the energy due to resistance in the wires along the way. On the other hand, data sent over long distances using fiber optics incurs almost no loss. It is recommended therefore, that those companies and organizations operating data centers, especially data centers housing Artificial Intelligence systems be encouraged to co-locate on public lands near these renewable energy sources to reduce the energy losses due to resistance.
2. COBOL Replacement – One of the stated goals of this administration is to replace COBOL. The problem with that is that COBOL is a statically typed programming language. Without a strongly typed programming language it is not possible to have provable code and the popular languages today, such as Python and Java Script. While Python can be strongly typed, it can also be dynamically typed. Java is strongly typed but is more of a nightmare for maintenance than is COBOL.

It is recommended that Artificial Intelligence be employed to write directly in the native machine language. Then, the prompts can be collected and saved under configuration management. Next, have the AI reverse engineer the machine language into Python. This will provide a one-way process to create code in the computer. The prompts will provide human readable documentation and the Python will augment that with a detailed view of what the machine code actually does.

I do not recommend using Python, or any of the other common languages in use today to replace COBOL directly. The Python version 2 to 3 debacle demonstrated that it is not managed well enough to be a viable long-term alternative to COBOL.

Java is not intuitive enough to be a long-term solution and its tendency to hide functionality creates the risk of a programmer embedding hidden malware inside of objects.

C# is proprietary and like Swift, Kotlin, Rust, Go, Haskell, Scala, Objective-C, TypeScript, Ruby, F#, and Dart, it is not certain that any of these languages have a sufficiently long future ahead of them to make adoption worthwhile.

Respectfully,

Patrick T. Stingley

